

Controle de Acesso e Autenticação

quinta-feira, 9 de abril de 2026 09:31

Conceitos de modelos e controles de acesso

Modelos de controle de acesso

Um modelo de acesso em segurança da informação é um conjunto de regras, diretrizes e políticas que descrevem como os recursos da organização podem ser acessados e utilizados por indivíduos ou sistemas. Ele define as estratégias e abordagens para controlar quem pode acessar quais recursos e sob quais condições. Vamos trazer alguns desses modelos:

- **DAC (Controle de Acesso Discrecional):** nesse modelo, os proprietários dos recursos determinam quem tem permissão para acessá-los. Cada usuário pode controlar o acesso a seus próprios recursos. É um modelo flexível, mas pode ser vulnerável se as permissões não forem configuradas corretamente.
- **MAC (Controle de Acesso Mandatório):** é baseado em políticas definidas por administradores ou regulamentações. Os usuários não têm controle sobre as permissões. É comumente usado em ambientes governamentais e militares.
- **RBAC (Controle de Acesso Baseado em Funções):** o acesso é concedido com base nas funções dos usuários na organização. Os usuários são atribuídos a funções que definem suas permissões. É eficaz para gerenciar grandes grupos de usuários.
- **ABAC (Controle de Acesso Baseado em Atributos):** permite o controle de acesso com base em diversos atributos, como identidade do usuário, tipo de dispositivo, localização e horário. Isso proporciona um alto grau de flexibilidade.

Controle de acesso

Os controles de acesso são mecanismos técnicos e procedimentais que implementam as políticas de segurança definidas pelo modelo de acesso. Eles são responsáveis por garantir que apenas usuários autorizados tenham acesso aos recursos de uma organização.

- **Autenticação:** é o processo de verificar a identidade do usuário. Isso pode envolver senhas, autenticação de dois fatores (2FA), autenticação biométrica, etc.
- **Autorização:** após a autenticação, a autorização determina quais ações um usuário pode realizar. Isso está relacionado às permissões de acesso.
- **Auditoria:** o monitoramento e registro de atividades de acesso são essenciais para a segurança. A auditoria ajuda a identificar comportamentos suspeitos e manter um histórico de eventos.
- **Políticas de acesso:** definem as regras que determinam quem tem acesso a recursos específicos. Elas são um componente crítico do controle de acesso.
- **Controle de privacidade:** deve estar em conformidade com regulamentos de privacidade, como a LGPD e o GDPR, garantindo que dados pessoais sejam protegidos.
- **Proteção contra ameaças internas:** os sistemas de controle de acesso devem lidar com ameaças internas, como funcionários mal-intencionados ou descuidados.
- **Gestão de Identidade e Acesso (IAM):** IAM envolve o gerenciamento de identidades de usuários, incluindo a criação, modificação e exclusão de contas de usuário, bem como o gerenciamento de direitos de acesso.

Mecanismos de autenticação e autorização

Para Silva (2023, p. 200), a tecnologia AAA (autenticação, autorização e auditoria), permite a autenticação e a autorização dos usuários baseadas no ID de usuário e senha. Temos algumas formas de trabalhar a autenticação:

- **Senha:** a autenticação baseada em senha é a forma mais comum, em que os usuários fornecem uma combinação de nome de usuário e senha para verificar sua identidade. É importante usar senhas fortes e implementar políticas de mudança regular de senhas.
- **Autenticação de dois fatores (2FA):** o 2FA adiciona uma camada extra de segurança, exigindo, além da senha, algo que o usuário possui (como um token ou aplicativo móvel) para verificar sua identidade.
- **Biometria:** envolve a verificação da identidade do usuário com base em características físicas, como impressões digitais, íris ou reconhecimento facial.
- **Certificados digitais:** são emitidos por autoridades de certificação e são usados para autenticar a identidade de usuários ou sistemas.

Na autorização, como já explicado, temos o DAC, MAC, RBAC e ABAC, que trabalham conforme determinação das permissões que um usuário tem após a autenticação. Isso envolve a atribuição de direitos de acesso específicos com base no modelo de acesso definido.

Temos também, na autorização:

- Políticas de acesso.
- Auditoria e monitoramento.
- Proteção contra ameaças internas.
- Gestão de identidade e acesso (IAM).

Mecanismos de autenticação e autorização são essenciais para proteger sistemas e dados, garantindo que apenas usuários autorizados tenham acesso a recursos específicos e que suas identidades sejam verificadas de maneira segura. O uso adequado desses mecanismos é fundamental para a segurança da informação e a conformidade com regulamentações de privacidade e segurança.

Sistemas de gerenciamento de identidades

Os Sistemas de Gerenciamento de Identidades (Identity and Access Management - IAM) são ferramentas e estruturas que auxiliam na administração e controle de identidades de usuários em um ambiente de tecnologia.

- **Autenticação e autorização:** os IAM fornecem mecanismos de autenticação para verificar a identidade dos usuários, como senhas, autenticação de dois fatores (2FA), biometria e certificados digitais. Além disso, esses sistemas gerenciam a autorização, controlando o acesso dos usuários a recursos com base em suas permissões.
- **Centralização de identidades:** permitem que as organizações centralizem o gerenciamento de identidades de usuários, tornando mais eficiente a criação, modificação e exclusão de contas de usuário em diversos sistemas e aplicativos.
- **Controle de acesso:** esses sistemas oferecem recursos para configurar e controlar permissões de acesso de usuários a aplicativos e recursos, garantindo que apenas os usuários autorizados tenham acesso.
- **Self-Service:** muitos IAM permitem que os usuários gerenciem suas próprias informações de identidade, como a redefinição de senhas, atualização de informações de contato e solicitações de acesso a novos recursos.
- **Proteção de dados e privacidade:** os IAM são projetados para proteger os dados pessoais dos usuários e garantir a conformidade com regulamentos de privacidade, como o GDPR e a LGPD.
- **Auditoria e monitoramento:** registram e monitoram as atividades de identidade e acesso, permitindo a detecção de atividades suspeitas e a geração de relatórios para fins de conformidade e segurança.
- **Federated Identity:** os sistemas de gerenciamento de identidades também suportam a autenticação federada, permitindo que os usuários acessem recursos em várias organizações com uma única identidade.
- **Gestão de senhas e autenticação única (Single Sign-On - SSO):** alguns IAM oferecem funcionalidades de gestão de senhas e SSO, permitindo que os usuários acessem vários aplicativos com uma única autenticação.
- **Integração de diretórios:** eles integram-se a diretórios de usuários, como o Active Directory, para simplificar o gerenciamento de identidades.
- **Gestão de ciclo de vida da identidade:** os IAM automatizam tarefas relacionadas ao ciclo de vida da identidade, como a criação de contas, atribuição de funções, atualizações e desativação de contas de usuário.